

Trust by Design

Built to run. Not to present.

Your AI Is in Production. Nobody Is Accountable for What It Does Next.

A practitioner's guide to the Enterprise AI Operating System — what it is, why most enterprises don't have it, and how to build the operating model that makes AI safe, governed, and worth the investment.

Enterprise AI doesn't fail because organizations lack AI tools. It fails because architecture, governance, security, and financial accountability are managed as four separate programs — with no operating system connecting them.

SECTION 1

What AI Governance Actually Means

AI governance is the organizational system for deciding which AI uses are permitted, who owns them, how risk is classified, what controls are required, who has authority to approve or accept risk, and how the system is monitored throughout its lifecycle.

It is not a committee, and it is not a policy PDF. It is the decision system that converts enterprise intent into repeatable operating decisions — covering ownership, inventory, risk classification, controls and approval, and lifecycle operation.

A low-impact internal drafting assistant should not face the same governance burden as an agent that can approve payments. TBD uses risk tiering so controls and oversight scale with consequence.

Most enterprises today have elements of governance scattered across teams — some risk classification here, a security review there, a business owner who isn't formally named. What they lack is the connecting tissue: a repeatable operating model that runs consistently from use-case intake through production and scale decisions.

SECTION 2

The Six Live Risks in Enterprise AI Environments Right Now

These are the conditions we find in active enterprise AI environments in 2026:

01

No Accountability Chain

AI systems in production with no audit trail and no designated owner when outputs cause harm.

02

Ungoverned Agentic AI

Autonomous agents taking consequential actions — sending emails, modifying data, executing transactions — with no human approval gate.

03

AI Spend Without ROI Attribution

Finance receives large model inference bills with no cost attribution by use case, team, or business outcome.

04

Shadow AI at Scale

Employees using unauthorized AI tools with sensitive organizational data — invisibly and at a scale security teams cannot see.

05

Multi-Model Complexity

Multiple models running in parallel with no orchestration layer, no unified evaluation framework, and no shared policy.

06

Regulatory Exposure

EU AI Act obligations phase in through 2027. FedRAMP 20X, StateRAMP, and HIPAA are introducing AI-specific controls for government and healthcare. Most organizations have no architecture-to-obligation mapping in place.

SECTION 3 · THE DETERMINISTIC SAFETY LAYER

Probabilistic Reasoning. Deterministic Control.

LLMs are probabilistic. The objective is not to make the model deterministic — it is to build a **deterministic system around probabilistic AI** so consequential decisions do not depend on the model policing itself.

The model may reason and propose. External systems must enforce identity, authorization, policy, approval, and execution limits.

HOW MOST ORGANIZATIONS BUILD

The Model Is the Governance Layer

- System prompt carries the policy
- Model decides what is compliant
- No external enforcement point
- No audit trail outside the model
- Jailbreakable. Not auditable. Not defensible.



THE TRUST BY DESIGN ARCHITECTURE

Deterministic Controls Outside the Model

- Policy enforced by external control plane
- Risk classification at intake, not inference
- HITL approval gates for consequential actions
- Immutable audit log independent of model
- Auditable. Defensible. Regulatorily mappable.

The five mechanisms that make controls deterministic:

MECHANISM	PURPOSE	WHAT BECOMES PREDICTABLE
Schema validation	Reject malformed or out-of-policy structured outputs.	Output format and validation path.
Quality / confidence thresholds	Escalate low-quality or uncertain results based on defined evaluation signals.	Escalation rule.
RAG grounding & provenance	Ground answers in authorized enterprise sources and retain source traceability.	Allowed source set and provenance path.
Human approval gates	Require accountable review for consequential actions regardless of model confidence.	Decision authority.
Audit trail	Record input, output, policy decision, approval, action, and result independently of the model.	Evidence path and accountability.

Important nuance: RAG does not guarantee truth, and a model-generated confidence score is not inherently calibrated. TBD therefore treats grounding, evaluation thresholds, and human review as controls that must be tested against the specific use case — not as guarantees of correctness.

SECTION 4 · FIVE OPERATING PRINCIPLES

Sequencing Rules for Enterprise Scale

TBD's principles are not slogans. They are sequencing rules for building governance that can survive enterprise scale — and for knowing which problem to solve first:

1. Visibility Before Control	You cannot govern what you cannot see. Start with inventory and shadow-AI discovery before layering controls.
2. Platform Before Headcount	Centralize repeatable capabilities — gateways, intake, controls, evaluation, evidence — before scaling bespoke integrations.
3. Governance as Enablement	The governed path must be easier than the workaround. Controls should accelerate safe adoption, not create a bypass incentive.
4. Earn Trust Before You Govern	Demonstrate value and remove real delivery pain before asking teams to adopt a new operating model.
5. Measure From Day One	Define baseline and success metrics before deployment so scale decisions are evidence-based, not optimistic.

Governance fails when it is introduced as a separate compliance program after architecture and delivery decisions have already been made. TBD moves governance and security into the delivery lifecycle while keeping business value visible from the start.

SECTION 4 · THE OPERATING SYSTEM

Build → Govern → Secure → Measure

These four pillars are the customer-facing model. Most organizations buy point solutions — a governance dashboard, a security scanner, a FinOps tool — and still lack the connecting tissue. TBD delivers all four disciplines as one operating system:

01 · BUILD Build • AI-native platform architecture • Agentic AI patterns & LLM gateways • RAG pipeline design & guardrails • Agent identity & least-privilege • Human-in-the-loop approval flows • MCP & tool security patterns	02 · GOVERN Govern • AI operating model & risk tiering • Intake framework & portfolio priority • NIST AI RMF / EU AI Act mapping • AI SteerCo design & exec alignment • Audit trail & compliance evidence • Shadow AI detection strategy	03 · SECURE Secure • Agentic AI threat modeling • OWASP LLM Top 10 controls • Prompt injection defenses • Data leakage & context provenance • LLM guardrail architecture • AI Bill of Materials (AI BOM)	04 · MEASURE Measure • AI FinOps & model cost attribution • Productivity baseline & ROI • Evaluation & quality frameworks • Portfolio maturity scoring • Board-level AI reporting • Adoption & impact dashboards
--	---	---	---

SECTION 5 · MARKET DIFFERENTIATION

Why Trust by Design Exists in a Crowded Market

AI governance, security, architecture, and measurement are established categories. TBD's claim is not that each discipline is unique. The differentiation is integrating them around one use case, one lifecycle, and one set of business outcomes:

TYPICAL APPROACH	PRIMARY STRENGTH	WHAT TBD ADDS
AI governance / GRC platform	Inventory, policy, risk workflow, evidence.	Architecture, implementation, runtime control design, and business-value measurement.
AI security product / specialist	Threat detection, technical control, or assurance depth.	Use-case prioritization, governance operating model, transformation, and ROI.
AI engineering consultancy	Build and integrate AI systems.	Risk-tiered governance, security-by-design, compliance evidence, and operating decisions.
Strategy consultancy	Portfolio strategy and organizational change.	Technical architecture and control patterns that can be implemented, tested, and operated — not just recommended.

TBD is complementary to existing cloud, IAM, GRC, security, observability, and AI platforms. The advisory value is designing the operating model and connecting those control planes to the AI lifecycle.

SECTION 5 · IMPLEMENTATION TOOLKIT

From Framework to Reusable Delivery Assets

TBD is intended to be implemented, not only presented. The toolkit packages repeatable methods into reusable artifacts that leave lasting capability behind:

ARTIFACT	WHAT IT COVERS
01 · Risk Tiering	Use-case classification, approval path, and monitoring requirements by tier.
02 · LLM Guardrail Patterns	Reusable patterns for input/output validation, PII handling, injection defense, rate limiting, and action gates.
03 · Agentic AI Threat Model	Threat scenarios around prompt injection, tool abuse, excessive authority, memory/context poisoning, and data exfiltration.
04 · Evaluation Framework	Readiness, pre-deploy testing, production monitoring, and post-launch review checkpoints.
05 · Compliance by Design	Maps AI architecture and controls to applicable obligations — EU AI Act, FedRAMP 20X, StateRAMP, HIPAA — so compliance is built in, not bolted on. Validated per client jurisdiction and use case.
06 · AI Productivity Measurement	Metrics for adoption, quality, review burden, delivery impact, and ROI across five dimensions.
07 · Enterprise LLM Case Study	Anonymized reference pattern based on prior Amazon Bedrock workflow and Google AI program experience.
08 · Transformation Starter Kit	A practical starting sequence for inventory, platform controls, governance, and executive reporting.

The design goal: leave reusable capability behind. A successful engagement gives the client an operating pattern, templates, control logic, measurements, and decision mechanisms that can be reused across subsequent AI initiatives.

SECTION 6 · EXPERIENCE AND PROOF POINTS

Built from Enterprise Transformation Experience

Trust by Design synthesizes lessons from firsthand delivery of enterprise AI, security, and transformation programs inside Google's Corporate Engineering organization and Amazon's Security platform. These are founder experience proof points — not claims that those companies use or endorse the TBD product or methodology:

50+ → 14

Governed 50+ AI/ML programs across 14 Google corporate verticals — intake framework, Finance-aligned impact model, SteerCo with 20+ Directors and SVPs. Portfolio: \$30–50M.

Google Corp Engineering AI Strategy

\$500M+

Salesforce ecosystem value unlocked across 150+ business units. Designed 12 security and privacy controls. Built Risk Inspector as mandatory governance platform. Partner onboarding: 150 days → 10 hours. 3,700+ licenses eliminated.

Google · 3P Security & Privacy (Tigerforce)

7wk → 1wk

Security request resolution improvement via Amazon Bedrock LLM pipeline — AI-driven triage and routing across 2,500+ security requests.

Amazon Security Platform · 2024–2025

180K · \$200M

Built single unified HR experience serving 180,000+ Googlers across People Ops, HR, Accommodations, and 20+ internal teams. Eliminated redundant tooling. Security & privacy controls drove \$200M in Salesforce licensing savings.

Google Corp Engineering · Unified HR Platform

40% · 70%+

Scorecard adoption increased 40% post-launch. 70%+ of Amazon engineering teams on standardized risk model. Full PM cycle: customer discovery → OP1/OP2 planning → ship.

Amazon Security Scorecard v2

WORKED EXAMPLE

Procurement Agent: One Use Case Through the Full System

USE CASE · PROCUREMENT AGENT

Business objective: reduce procurement cycle time by allowing an AI agent to assemble purchase requests, retrieve approved vendor/policy information, and prepare transactions for accountable approval.

BUILD: RAG over procurement policy and approved vendor data. Agent orchestration with procurement APIs. Deterministic authorization layer before any transaction is prepared. Reliability baseline established. Rollback plan defined before launch.

GOVERN: Named owner designated. Use case inventoried with data and autonomy classification. Risk tier assigned (Tier 3 — consequential, material actions). Approval authority, exception handling, and material-change triggers documented.

SECURE: Unique agent identity with least-privilege scopes. Permission-aware retrieval. Schema validation on all tool calls. Transaction limits and vendor allowlists enforced at the authorization layer — not inside the model. HITL required before any commitment above threshold. Complete action tracing to immutable audit store.

MEASURE / OPTIMIZE: Cycle-time, successful request rate, human correction rate, policy violations, adoption, and realized savings — tracked against baseline on a board-ready scorecard.

The TBD differentiation is the connection: the business objective, architecture, governance decision, technical controls, and measurements are designed as one system — before deployment, not retrofitted after an incident.

SECTION 7 · EXPERIENCE AND ENGAGEMENT

What Engagement Actually Looks Like

Every engagement starts with a risk and architecture assessment of one high-value use case — because the fastest way to understand an organization's AI governance maturity is to examine one live system end to end. From that baseline, we build the operating system around it and expand.

PHASE	WHAT WE DO	WHAT YOU GET	OUTCOME
Weeks 1–2 AI Risk & Architecture Assessment	Assess one high-value AI use case end to end — architecture, data flows, risk classification, governance gaps, security posture.	Risk-tiered use case inventory. Gap analysis against NIST AI RMF. Prioritized remediation roadmap with effort and impact scores.	A CIO-ready view of where the organization's AI risk actually lives — not where people assume it does.
Days 30–90 90-Day Build-Govern-Secure-Measure	Implement the full operating system for one use case — intake process, risk controls, security architecture, FinOps baseline, audit trail, executive reporting.	Live operating model. Governance documentation. Compliance evidence package. Board-ready AI scorecard.	A repeatable template the organization can apply to every subsequent AI initiative — without rebuilding from scratch each time.
Ongoing Fractional Chief AI Officer	Embedded advisory across the full AI portfolio — architecture reviews, governance decisions, security posture, regulatory readiness, board reporting.	A senior AI leader in the room — operating model ownership, portfolio oversight, executive-level communication.	The ongoing capability a mature AI organization needs, without the cost or hiring timeline of a full-time CAO.

HOW TO START

SPRINT

AI Risk & Architecture Assessment
Two-week fixed engagement. One high-value use case assessed end to end. Risk classification, governance gaps, prioritized roadmap delivered.

Fixed fee · 2 weeks

PILOT

90-Day Build-Govern-Secure-Measure
Full operating system implemented for one AI use case. Intake through production. Governance docs, security controls, FinOps baseline, board reporting.

Project-based · 90 days

FRACTIONAL

Fractional Chief AI Officer
Ongoing embedded advisory. Architecture, governance, regulatory readiness, board-level reporting — senior resource without the full-time cost.

Engagement-based · Ongoing

Start with a 2-week AI Risk & Architecture Assessment.
Concrete findings on one high-value use case. A roadmap you can act on the same week.

[gurukrish.org](#)
krish@gurukrish.org

FRAMEWORKS & SOURCE MATERIAL

References

Regulatory & Standards Frameworks

NIST AI Risk Management Framework (AI RMF 1.0)

Voluntary framework for managing AI risk. Core functions: Govern, Map, Measure, and Manage. TBD uses it as a risk-management reference, not a certification. NIST notes that AI RMF 1.0 is being revised as of 2026.
Source: National Institute of Standards and Technology — AI RMF and AI Resource Center · nist.gov/artificial-intelligence

ISO/IEC 42001:2023 — AI Management System Standard

International standard for establishing, implementing, maintaining, and improving an AI Management System (AIMS). TBD can map operating practices and evidence to relevant concepts; it does not itself certify an organization.
Source: International Organization for Standardization · iso.org

EU Artificial Intelligence Act (2024/1689)

Risk-based regulatory framework for AI systems in the European Union. High-risk system obligations phase in through August 2027. Extraterritorial reach applies where AI outputs are used in the EU. Applicable law and sector requirements vary by jurisdiction, role, and use case — clients should obtain appropriate legal advice.
Source: Official Journal of the European Union · eur-lex.europa.eu

OWASP GenAI / LLM Security Guidance

Practical security guidance for threats affecting LLM, GenAI, and agentic applications, including prompt injection, sensitive information disclosure, excessive agency, and related application/agent risks. TBD uses these sources to inform threat modeling and control design.
Source: OWASP GenAI Security Project · owasp.org/www-project-gen-ai-security

FedRAMP 20X / StateRAMP

Federal and state cloud authorization programs introducing AI-specific controls and requirements for government and regulated industry AI deployments. Framework and regulatory applicability should be validated for each client context.
Source: General Services Administration · fedramp.gov; StateRAMP · stateramp.org

About Trust by Design

Trust by Design is an enterprise AI advisory and operating framework focused on helping organizations move AI from fragmented experimentation to production capabilities that are architected for value, governed by clear decision rights, secured through enforceable controls, and measured against business outcomes.

Guru Krish · Founder, Trust by Design
gurukrish.org · krish@gurukrish.org

Important Note: Trust by Design provides advisory, architecture, and implementation guidance. Regulatory and compliance requirements vary by jurisdiction, sector, role, and use case. Clients should obtain appropriate legal and compliance advice for binding interpretations and conformity obligations. Framework references reflect publicly available versions as of the publication date. Metrics cited reflect outcomes from the author’s prior enterprise delivery roles at Google and Amazon; they are founder experience proof points — not claims that those companies use or endorse the Trust by Design product or methodology. The public narrative should remain consistent: Build → Govern → Secure → Measure is the client-facing operating model; the Deterministic Safety Layer is the technical control principle; the toolkit turns the model into reusable delivery assets.